WINTER 2026/27 EDITION, REVISED

Remote Access Is a Governance Problem

Securing remote access to industrial machines in Belgium and the Netherlands

Software Lantern. Sources checked as of 21 October 2026.

This is a general guide based on published sources. It is not legal or security advice. Confirm your specific obligations with the official sources cited or a qualified advisor.

Industrial remote access is a governance problem: identities, machines, suppliers, sites and lifecycle, not only a connectivity problem. The question is not whether the engineer can get in, but who can get in, to what, until when, approved by whom, and what proves it afterwards.

Written for the OT security lead or CISO at a manufacturer in Belgium or the Netherlands, and for the service director at a machine builder who sits on the other end of the same connection.

How to read this report

Every block carries one label. Short citations in the text link to their source; the full source line for each, with its check date and Official Journal reference, is in Appendix B.

DATA A verified fact from a primary source: an official legal text, an official record, or an official dataset. Each carries its source and the date it was checked.

INTERPRETATION Our reading of what the data means for remote access. Shown as such, so you can disagree with it.

MODEL Arithmetic on inputs you supply, or on inputs marked illustrative. A model is never a finding about anyone.

Contents

Part 1	Executive briefing
Part 2	How remote access spreads
Part 3	How governance fails
Part 4	A five-dimension assessment
Part 5	From regulation to action
Part 6	Two public incidents
Part 7	A 90-day plan
Part 8	Regional context
Appendix A	The 25-point matrix, prioritised
Appendix B	Methodology and sources

PART 1

Executive briefing

Four findings. Each states what the evidence says (Data), then what it means for the plant's security lead and for the machine builder (Interpretation).

1. Both verified incidents turned on valid access, not on broken connectivity.

DATA In the Colonial Pipeline case the chief executive testified that the attacker used a legacy VPN profile that was no longer meant to be in use, protected by a single factor. In the 2015 attack on Ukrainian power distribution companies, the agency alert records that the attackers held legitimate credentials and operated breakers over existing remote administration tools and VPN connections. Part 6 quotes both records.

DATA Sources: Colonial Pipeline hearing record, S. Hrg. 117-429; Ukrainian power distribution companies agency alert, IR-ALERT-H-16-056-01.

INTERPRETATION **For the plant:** The control that mattered was who held a working credential and whether it should still have existed, not the strength of the tunnel.

INTERPRETATION **For the builder:** Every service account you leave behind at a customer site is part of the customer's attack surface, whether or not anyone uses it.

2. The EU rules describe remote access as governance, not as a technology.

DATA NIS2 lists access control policies, asset management, supply chain security and, where appropriate, multi-factor authentication among the minimum measures, and makes management bodies approve and oversee them. None of these provisions names a product or a technology.

DATA Sources: Directive (EU) 2022/2555, Art. 21(2)(j); Directive (EU) 2022/2555, Art. 21(2)(j); Directive (EU) 2022/2555, Art. 21(2)(d); Directive (EU) 2022/2555, Art. 20(1).

INTERPRETATION **For the plant:** What an auditor can ask for is a policy and the evidence that it is followed. The artefact is a register and a record, not a purchase order.

INTERPRETATION **For the builder:** Customers in scope will ask how your access is governed, because their own management has to approve how they manage supplier risk.

3. Product law moves part of the evidence burden onto the machine builder.

DATA The Cyber Resilience Act requires products with digital elements to protect against unauthorised access and to record relevant access activity. The Machinery Regulation requires machinery to record evidence when its software or configuration is intervened in or modified, whether legitimately or not, and connections from remote devices must not lead to a hazardous situation.

DATA Sources: Regulation (EU) 2024/2847, Annex I, Part I, point (2)(d); Regulation (EU) 2024/2847, Annex I, Part I, point (2)(l); Regulation (EU) 2023/1230, Annex III, section 1.1.9.

INTERPRETATION **For the plant:** Ask the builder what the machine itself records about remote interventions, and how you can read it.

INTERPRETATION **For the builder:** The service channel shipped with a machine is part of what is placed on the market, so its access controls and records are design questions, not only service-desk questions.

4. Most machine builders meet these rules through their customers first.

DATA By headcount, enterprises with 50 or more persons employed are 8.9% of machinery and equipment manufacturers (NACE C28) in Belgium and 9.5% in the Netherlands (Part 8), so most are unlikely to be in NIS2 scope on size alone. NIS2 still brings the questions to them: in-scope customers must weigh the security practices of each direct supplier and service provider.

DATA Sources: Eurostat sbs_sc_ovw, 2024; Directive (EU) 2022/2555, Art. 2(1); Directive (EU) 2022/2555, Art. 21(3).

INTERPRETATION **For the plant:** Your supplier questionnaire is how the rules reach most of the builders you depend on. Make it ask governance questions (Appendix A), not product questions.

INTERPRETATION **For the builder:** Expect the customer's questionnaire to be the real compliance channel, and prepare evidence once for all customers.

PART 2

How remote access spreads

INTERPRETATION Remote access grows by multiplication, not addition. Each supplier brings its own technicians, and each of them may need to reach each site. This model does the arithmetic on your own numbers so the size of the governance job is visible before anyone discusses tools.

MODEL: ARITHMETIC ON ILLUSTRATIVE INPUTS, NOT A FINDING

Worked example. The inputs below are illustrative, not observed, and not typical of anyone. Use the open web version of this report to run the model on your own numbers.

Input	Meaning	Illustrative
S	Suppliers with remote access	**6**
T	Sites	**3**
E	Technicians per supplier with access	**4**
h	Share of supplier-site access on shared (not named) accounts, 0 to 1	**1**
c	Technician changes per supplier per year (joiners plus leavers)	**2**

Output	Formula	Working	Result
Person-to-site access paths (P)	`S × T × E`	`6 × 3 × 4`	**72**
Supplier-site pairs	`S × T`	`6 × 3`	**18**
Shared credentials in use	`h × S × T`	`1 × 18`	**18, each known by 4 people**
Shared-credential rotations a year	`h × S × T × c`	`1 × 18 × 2`	**36**
Named-account changes a year	`(1 − h) × S × T × c`	`0 × 18 × 2`	**0**

MODEL **Assumptions**

- Every technician of a supplier with access can reach every site that supplier serves. Where access is narrower, P is smaller; use your own inventory.
- A shared account is shared per supplier per site, so every technician of that supplier knows it.
- Each technician change at a supplier (a joiner or a leaver) touches that supplier's access at every site: a shared credential to rotate, or a named account to create or remove.

INTERPRETATION **Reading the model**

- Named accounts do not remove the administrative work: a technician change touches every site either way. They change what the work achieves. Removing one named account removes one person. Rotating a shared credential disrupts everyone else who uses it, so each rotation has a cost for people who did nothing wrong.
- A shared credential known by E people cannot show which of them connected. Every shared credential is a gap in the evidence trail as well as in identity.
- The model counts paths, not risk. A path that is closed between jobs and opened on request carries less exposure than a standing one; that is the availability dimension in Part 4.

INTERPRETATION **Where sprawl hides**

Dealers and subcontractors. The technicians who connect may work for a dealer or subcontractor of the supplier, so the plant may not know E, and it can change without the plant being told.

Temporary accounts on the plant side. Accounts created for one commissioning job or one urgent repair, and never removed because nobody owned their removal.

Standing tunnels. Connections left up between jobs because reconnecting is inconvenient, so access exists whether or not anyone is working.

PART 3

How governance fails

Five ways governance of remote access fails. Each shows what it looks like, which rule or public record it maps to, and what fixed looks like.

Shared or single-factor accounts

INTERPRETATION **What it looks like:** One login per supplier, known by every technician, often with a password alone. The plant cannot say who connected, and a leaver keeps a working secret.

DATA NIS2 names access control policies and, where appropriate, multi-factor authentication. The CRA asks products to protect against unauthorised access through authentication, identity or access management. Both incidents turned on credentials that worked.

DATA Sources: Directive (EU) 2022/2555, Art. 21(2)(i); Directive (EU) 2022/2555, Art. 21(2)(j); Regulation (EU) 2024/2847, Annex I, Part I, point (2)(d); Colonial Pipeline hearing record, S. Hrg. 117-429; Ukrainian power distribution companies agency alert, IR-ALERT-H-16-056-01.

INTERPRETATION **What fixed looks like:** One account per person, with a second factor, for supplier staff as well as your own. Exceptions are written down with a reason and an end date.

Standing access

INTERPRETATION **What it looks like:** Access that is always on, so the path exists between jobs, overnight and at weekends.

DATA The agency alert on the Ukrainian attack recommends that remote access be operator controlled and time limited. NIS2 makes the security of supplier relationships part of the minimum measures.

DATA Sources: Ukrainian power distribution companies agency alert, IR-ALERT-H-16-056-01; Directive (EU) 2022/2555, Art. 21(2)(d).

INTERPRETATION **What fixed looks like:** Access opened on request, approved by the plant, with an end time, and an emergency path that is itself logged.

Unclear ownership

INTERPRETATION **What it looks like:** Nobody can name, for a given path, who on the plant side and who on the supplier side is responsible for it.

DATA NIS2 makes management bodies approve and oversee the risk-management measures, and requires in-scope entities to take account of each direct supplier's vulnerabilities and practices.

DATA Sources: Directive (EU) 2022/2555, Art. 20(1); Directive (EU) 2022/2555, Art. 21(3).

INTERPRETATION **What fixed looks like:** Two named owners per path, one at the plant and one at the supplier, recorded in the remote access register.

Weak revocation

INTERPRETATION **What it looks like:** Access is removed only when someone remembers, or only with the supplier's help. Old profiles survive changes of staff, projects and systems.

DATA In the Colonial Pipeline testimony, the profile used was a legacy one that was not intended to be in use.

DATA Sources: Colonial Pipeline hearing record, S. Hrg. 117-429.

INTERPRETATION **What fixed looks like:** A tested revocation: one leaver's access removed end to end, on every path, within a target time you set, and the result recorded.

No evidence trail

INTERPRETATION **What it looks like:** Sessions are not logged, or the logs sit with a third party and cannot be exported. After an incident nobody can reconstruct what happened.

DATA The CRA asks products to record relevant access activity. The Machinery Regulation asks machinery to collect evidence of intervention in its software and configuration, and to keep a tracing log of interventions and safety-software versions.

DATA Sources: Regulation (EU) 2024/2847, Annex I, Part I, point (2)(l); Regulation (EU) 2023/1230, Annex III, section 1.1.9; Regulation (EU) 2023/1230, Annex III, section 1.2.1.

INTERPRETATION **What fixed looks like:** A written logging standard: what is recorded per session, where, for how long, and who can export it. Proven by reconstructing one real session from the logs alone.

PART 4

A five-dimension assessment

INTERPRETATION Five dimensions of remote access governance. Mark each one verified, partial or unknown for your own setup.

Mark a dimension verified only if you could hand the evidence to an auditor today. A belief that it is fine is partial at best. An unknown is not a failure; it is the first item on the plan in Part 7.

Dimension	Verified means	Partial	Unknown	Your mark
Identity Is every remote session tied to one named person, with a second factor?	An account list mapping each account to one person, supplier staff included, and configuration showing the second factor is enforced.	Named accounts exist, but some are shared, or the second factor is optional.	You cannot produce the account list for supplier access.	☐ V ☐ P ☐ U
Scope Can each person reach only the machines they service?	Rules or policies showing per-supplier or per-person targets, and a test showing a session cannot reach anything else.	Access is limited to a network segment, not to the machine.	Nobody has checked what a remote session can reach.	☐ V ☐ P ☐ U
Lifecycle Is access granted for a reason and removed when the reason ends?	Dated grant and removal records, including for supplier leavers, and one tested revocation.	Access is removed on request, but there is no record or no test.	You do not know whether former supplier staff still have access.	☐ V ☐ P ☐ U
Evidence Can you reconstruct who did what, and when, after the fact?	Session logs kept for a defined period, exportable by you, and one session reconstructed from them.	Connections are logged, but not what happened in the session, or the logs cannot be exported.	You do not know where the logs are or how long they are kept.	☐ V ☐ P ☐ U
Availability Is access available when needed, and off when not?	A written procedure for opening access on request with approval and an end time, and a tested emergency path.	Access works when needed but is always on.	You do not know when remote paths are open.	☐ V ☐ P ☐ U

Six access architectures against the five dimensions

INTERPRETATION Each architecture constrains some things by design and leaves others to configuration. None settles all five dimensions on its own, and the same architecture can be governed well or badly. There is no score and no ranking here: read across a row to see what you would still have to configure and evidence yourself.

VPN into the customer network

Assumption: A client VPN terminating on the plant or corporate network.

Dimension	Constrained by design	Depends on configuration	Residual risk
Identity	Authenticates a VPN account.	Whether accounts are named and a second factor is enforced.	A valid credential opens the whole tunnel.
Scope	Network-level reach.	Firewall rules behind the VPN endpoint.	Reach is often wider than the machine being serviced.
Lifecycle	Nothing beyond the account existing.	Account expiry and a removal process.	Unused profiles persist until someone removes them.
Evidence	Connection records: who connected and when.	Whether activity inside the session is recorded elsewhere.	What was done in the session is usually not recorded by the VPN itself.
Availability	Available whenever the account is valid.	Enabling accounts only on request.	Standing access unless deliberately switched off.

Remote support tools

Assumption: Screen-sharing or remote-desktop software on a device at the plant, connected through a relay.

Dimension	Constrained by design	Depends on configuration	Residual risk
Identity	Tool accounts or one-time session codes.	Named accounts, second factor, whether ad hoc codes are allowed.	Session codes can be passed on.
Scope	The one device running the software.	What that device can reach onward.	The device can become a stepping stone.
Lifecycle	Per session when someone at the device accepts it.	Whether unattended access is enabled.	Unattended mode is standing access.
Evidence	Session events, sometimes a recording.	Recording switched on and retained.	Records may sit with the tool's operator unless exported.
Availability	On demand when attended.	Attended or unattended mode.	Attended mode depends on someone being at the device.

Jump hosts

Assumption: A hardened host between the external connection and the OT network, reached over a VPN or remote desktop.

Dimension	Constrained by design	Depends on configuration	Residual risk
Identity	Logons at the host, separate from OT accounts.	Named logons and a second factor at the host.	Shared administrator logons on the host.
Scope	One choke point.	What the host is allowed to reach.	A compromised host exposes everything it can reach.
Lifecycle	One central place to remove access.	Whether removal actually happens there.	The host itself must be kept patched.
Evidence	One place to log.	Session recording and retention.	Logs on the host can be changed by its administrators.
Availability	Usually always on.	Disabling accounts between jobs.	Access depends on one host being up.

Cloud zero-trust brokers

Assumption: Per-user, per-resource policy evaluated by a cloud-hosted broker, with a connector inside the plant.

Dimension	Constrained by design	Depends on configuration	Residual risk
Identity	Per user and device, usually through an identity provider.	Second factor and device checks in that identity provider.	Inherits the identity provider's own weaknesses.
Scope	Per-resource policies.	How narrowly resources are defined.	Broad policies recreate network-level access.
Lifecycle	Access follows identity provider membership.	Who manages supplier identities.	Supplier accounts may sit outside your own leaver process.
Evidence	Per-connection records.	Retention and export to your own systems.	Records held by a third party.
Availability	Policy-driven, can be time-bound.	Time windows and approval steps.	Depends on the broker and internet access; not every customer's policies accept a cloud broker.

OT gateways

Assumption: A dedicated device at the edge of the OT network that terminates remote connections, managed by the builder or the operator.

Dimension	Constrained by design	Depends on configuration	Residual risk
Identity	Gateway or management-portal accounts.	Named accounts and a second factor.	Builder-side accounts may be managed by the builder alone.
Scope	Terminates at the edge and reaches defined assets.	Per-user asset lists.	Rules drift if nobody keeps them current.
Lifecycle	Central account management in the portal.	Who removes supplier users, and when.	Another device to keep patched for the machine's life.
Evidence	Connection records at the gateway.	Retention and whether the customer can read them.	Records may live only in the builder's portal.
Availability	Can be enabled per session.	On-request mode, local enable switch.	One more device that can fail.

Hardware-enforced access

Assumption: A physical switch or key on site that must be engaged before a remote path can reach the machine, combined with one of the other architectures.

Dimension	Constrained by design	Depends on configuration	Residual risk
Identity	None on its own.	Identity controls of the path it gates.	Inherits that path's identity weaknesses.
Scope	Physical cut per machine or cell.	How it is wired.	Little beyond the gated path itself.
Lifecycle	Access ends when the switch is off.	A procedure for switching off.	A switch left on.
Evidence	Physical state, sometimes logged.	Whether switch state is recorded.	Who turned it on may go unrecorded.
Availability	Needs a person on site.	An on-call procedure.	Delay in urgent cases.

For a longer description of each architecture and what to ask about it, see the remote access approaches guide.

PART 5

From regulation to action

Three EU acts, three different things regulated. For each: who is in scope, the provisions that touch remote access (quoted, Data), what they mean for remote access and what evidence to keep (Interpretation). Only provisions verified against the official text are quoted.

> None of the provisions quoted in this part names a product, a technology or a supplier. They set outcomes and obligations. How you meet them is your decision, and an existing setup that is well governed and evidenced may already do so.

NIS2 (Directive (EU) 2022/2555)

Regulates: The organisation: how an in-scope entity manages cyber risk.

INTERPRETATION **Scope:** Machinery manufacturers (NACE C28) are listed in Annex II. Whether a given company is in scope also depends on the size rule, applied to its linked group.

DATA Sources: Directive (EU) 2022/2555, Art. 2(1); Directive (EU) 2022/2555, Art. 3(2); Directive (EU) 2022/2555, Annex II, point 5(d).

DATA **NIS2 in force in Belgium (Law of 26 April 2024): 18 October 2024** (applies as of the edition date). Source: Law of 26 April 2024 (Moniteur belge), Art. 98, checked 19 October 2026

DATA **Cyberbeveiligingswet (NIS2) in force in the Netherlands: 15 August 2026** (applies as of the edition date). Source: Staatsblad 2026, 187 and 189 (Art. 35), checked 19 October 2026

DATA **THE PROVISIONS**

> **Article 20(1):** "Member States shall ensure that the management bodies of essential and important entities approve the cybersecurity risk-management measures taken by those entities in order to comply with Article 21, oversee its implementation and can be held liable for infringements by the entities of that Article."

Source: Directive (EU) 2022/2555, Art. 20 (1), checked 21 October 2026. OJ L 333, 27.12.2022, p. 80.

> **Article 21(2)(i):** "human resources security, access control policies and asset management;"

Source: Directive (EU) 2022/2555, Art. 21(2)(i), checked 21 October 2026. OJ L 333, 27.12.2022, p. 80.

> **Article 21(2)(j):** "the use of multi-factor authentication or continuous authentication solutions, secured voice, video and text communications and secured emergency communication systems within the entity, where appropriate."

Source: Directive (EU) 2022/2555, Art. 21(2)(j), checked 21 October 2026. OJ L 333, 27.12.2022, p. 80.

> **Article 21(3):** "Member States shall ensure that, when considering which measures referred to in paragraph 2, point (d), of this Article are appropriate, entities take into account the vulnerabilities specific to each direct supplier and service provider and the overall quality of products and cybersecurity practices of their suppliers and service providers, including their secure development procedures."

Source: Directive (EU) 2022/2555, Art. 21(3), checked 21 October 2026. OJ L 333, 27.12.2022, p. 80.

INTERPRETATION **What it means for remote access**

- Supplier remote access is part of supply chain security and of access control, so it belongs in the measures management approves.
- Multi-factor authentication is named, qualified by "where appropriate". Recording why it is or is not appropriate for each path is itself evidence.
- In-scope customers have to weigh each direct supplier's practices, which is why builders receive questionnaires.

INTERPRETATION **Evidence to keep**

- A remote access register: every path, its owners, its account type.
- Supplier assessments covering remote access.
- Configuration showing where a second factor is enforced, and the reasoning where it is not.
- Minutes or sign-off showing management approved the measures.

Cyber Resilience Act (Regulation (EU) 2024/2847)

Regulates: The product: products with digital elements placed on the EU market.

INTERPRETATION **Scope:** Where a machine or its remote service component is a product with digital elements, its manufacturer carries these obligations.

DATA Sources: Regulation (EU) 2024/2847, Art. 2(1); Regulation (EU) 2024/2847, Art. 13(1).

DATA **Cyber Resilience Act, Article 14, applies: 11 September 2026** (applies as of the edition date). Source: Regulation (EU) 2024/2847, Art. 71(2), checked 19 October 2026. OJ L, 2024/2847, 20.11.2024.

DATA **Cyber Resilience Act fully applies: 11 December 2027** (applies after the edition date). Source: Regulation (EU) 2024/2847, Art. 71(2), checked 19 October 2026. OJ L, 2024/2847, 20.11.2024.

DATA **THE PROVISIONS**

> **Annex I, Part I, (2)(d):** "ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access;"

Source: Regulation (EU) 2024/2847, Annex I, Part I, point (2)(d), checked 21 October 2026. OJ L, 2024/2847, 20.11.2024.

> **Annex I, Part I, (2)(j):** "be designed, developed and produced to limit attack surfaces, including external interfaces;"

Source: Regulation (EU) 2024/2847, Annex I, Part I, point (2)(j), checked 21 October 2026. OJ L, 2024/2847, 20.11.2024.

> **Annex I, Part I, (2)(l):** "provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user;"

Source: Regulation (EU) 2024/2847, Annex I, Part I, point (2)(l), checked 21 October 2026. OJ L, 2024/2847, 20.11.2024.

> **Article 13(8), first subparagraph:** "Manufacturers shall ensure, when placing a product with digital elements on the market, and for the support period, that vulnerabilities of that product, including its components, are handled effectively and in accordance with the essential cybersecurity requirements set out in Part II of Annex I."

> **Article 13(8), third subparagraph:** "Without prejudice to the second subparagraph, the support period shall be at least five years. Where the product with digital elements is expected to be in use for less than five years, the support period shall correspond to the expected use time."

Source: Regulation (EU) 2024/2847, Art. 13(8), checked 21 October 2026. OJ L, 2024/2847, 20.11.2024.

> **Article 14(1):** "A manufacturer shall notify any actively exploited vulnerability contained in the product with digital elements that it becomes aware of simultaneously to the CSIRT designated as coordinator, in accordance with paragraph 7 of this Article, and to ENISA."

Source: Regulation (EU) 2024/2847, Art. 14(1), checked 21 October 2026. OJ L, 2024/2847, 20.11.2024.

INTERPRETATION **What it means for remote access**

- A remote service function shipped with the product is part of what has to protect against unauthorised access and record relevant access activity.
- External interfaces count toward the attack surface the product has to limit. A remote access port is an external interface.
- Vulnerabilities in the product, its components included, have to be handled for the support period, so the remote access component's update path is part of the product's.

INTERPRETATION **Evidence to keep**

- For builders: the design record showing how the product's remote access meets Annex I, and the support period you have set.
- For operators: the builder's statement of support period and update path for each installed component.

INTERPRETATION The CRA also lists identity and privileged access management products, and products with a VPN function, among its important products (Class I). That classification affects how the manufacturers of those products demonstrate conformity. It does not oblige anyone to use such products.

> **Annex III, Class I, point 1:** "Identity management systems and privileged access management software and hardware, including authentication and access control readers, including biometric readers"

> **Annex III, Class I, point 5:** "Products with digital elements with the function of virtual private network (VPN)"

Source: Regulation (EU) 2024/2847, Annex III, Class I, points 1 and 5, checked 21 October 2026. OJ L, 2024/2847, 20.11.2024.

Machinery Regulation (Regulation (EU) 2023/1230)

Regulates: Safety: machinery placed on the market, including protection against corruption and malicious attempts that could create a hazard.

INTERPRETATION **Scope:** The essential health and safety requirements in Annex III bind the manufacturer, and anyone who substantially modifies machinery becomes one.

DATA Sources: Regulation (EU) 2023/1230, Art. 10 (1).

DATA **Machinery Regulation (EU) 2023/1230 applies: 14 January 2027** (applies after the edition date). Source: Regulation (EU) 2023/1230, Art. 54, checked 19 October 2026. OJ L 165, 29.6.2023, p. 1.

DATA THE PROVISIONS

> **Annex III, 1.1.9, first paragraph:** "The machinery or related product shall be designed and constructed so that the connection to it of another device, via any feature of the connected device itself or via any remote device that communicates with the machinery or related product does not lead to a hazardous situation."

> **Annex III, 1.1.9, last paragraph:** "The machinery or related product shall collect evidence of a legitimate or illegitimate intervention in the software or a modification of the software installed on the machinery or related product or its configuration."

Source: Regulation (EU) 2023/1230, Annex III, section 1.1.9, checked 21 October 2026. OJ L 165, 29.6.2023, p. 1.

> **Annex III, 1.2.1, point (a):** "they can withstand, where appropriate to the circumstances and the risks, the intended operating stresses and intended and unintended external influences, including reasonably foreseeable malicious attempts from third parties leading to a hazardous situation;"

> **Annex III, 1.2.1, point (f):** "the tracing log of the data generated in relation to an intervention and of the versions of safety software uploaded after the machinery or related product has been placed on the market or put into service is enabled for five years after such upload, exclusively to demonstrate the conformity of the machinery or related product with this Annex further to a reasoned request from a competent national authority."

Source: Regulation (EU) 2023/1230, Annex III, section 1.2.1, checked 21 October 2026. OJ L 165, 29.6.2023, p. 1.

> **Article 18, first paragraph (opening):** "A natural or legal person that carries out a substantial modification of machinery or a related product shall be considered to be a manufacturer for the purposes of this Regulation and shall be subject to the obligations of the manufacturer set out in Article 10 for that machinery or related product"

> **Article 3, point (16) (opening):** "'substantial modification' means a modification of machinery or a related product, by physical or digital means after that machinery or related product has been placed on the market or put into service, which is not foreseen or planned by the manufacturer, and which affects the safety of that machinery or related product, by creating a new hazard, or by increasing an existing risk"

Source: Regulation (EU) 2023/1230, Art. 18 and Art. 3, point (16), checked 21 October 2026. OJ L 165, 29.6.2023, p. 1.

INTERPRETATION **What it means for remote access**

- A remote connection to the machine must not lead to a hazardous situation, which makes remote access a safety design question, not only an IT one.
- The machine has to collect evidence of intervention in its software and configuration. Remote changes are interventions.
- A modification by digital means can be substantial. An integrator or operator who changes safety-relevant behaviour remotely should check whether it has become the manufacturer.

INTERPRETATION **Evidence to keep**

- For builders: the risk assessment covering remote connection, and how the machine records interventions.
- For integrators and operators: a record of remote changes to safety-relevant software, and the assessment of whether any was a substantial modification.

DATA NIS2 in Belgium and the Netherlands

Belgium

In force since: 18 October 2024

Supervisory authority: Arrêté royal du 9 juin 2024 (Moniteur belge), Art. 3§1, checked 20 October 2026

Registration: Law of 26 April 2024 (Moniteur belge), Art. 13§1, checked 20 October 2026

Incident reporting: Law of 26 April 2024 (Moniteur belge), Art. 35 §1, checked 20 October 2026

"Without undue delay and in any case within twenty-four hours of becoming aware of the significant incident, an early warning indicating, where relevant, whether the significant incident is suspected to be caused by unlawful or malicious acts or could have a cross-border impact. Without undue delay and in any case within seventy-two hours of becoming aware of the significant incident, an incident notification updating the information referred to in point 1° and providing an initial assessment of the significant incident, including its severity and impact, as well as indicators of compromise where available."

Netherlands

In force since: 15 August 2026

Supervisory authority: NCSC-NL, Cyberbeveiligingswet (NIS2) referral-tree overview, checked 20 October 2026

Registration: RDI, "Registratieplicht Cyberbeveiligingswet", checked 20 October 2026

Incident reporting: NCSC-NL, "Meld incidenten onder de Cyberbeveiligingswet (meldplicht)", checked 20 October 2026

"Early warning within 24 hours. Notification within 72 hours. Final report within 1 month after your notification."

Luxembourg: NIS2 in force since 10 May 2026; competent authority, registration and incident notification per ILR, "Cybersecurity – NISS", checked 20 October 2026.

Excluded: not verified or not applicable

Commission Implementing Regulation (EU) 2024/2690. It applies to the digital-infrastructure entity types named in NIS2 Article 21(5), not to manufacturers. Using it for this audience would overclaim.

Belgium's CyberFundamentals framework as a conformity route. Not verified from an official text for this edition.

The specific measures in the Dutch implementing decree. Not verified from the official text for this edition.

Which CRA conformity-assessment procedure applies to Class I products. Not verified for this edition, so the report does not state one.

Industry statistics on remote-access incidents, supplier counts or breach costs. None found from a primary source that meets this report's rules.

PART 6

Two public incidents

Two cases, chosen because their primary records are public and uncontested and because each speaks to remote access. Each is shown as the record states it, then read against the five dimensions. They illustrate failure patterns; they are not a measure of how common those patterns are.

Colonial Pipeline, 2021

DATA **WHAT THE RECORD SAYS**

> "Although the investigation is still ongoing, we believe the attacker exploited the legacy VPN profile that was not intended to be in use."
> Colonial Pipeline chief executive, testimony

> "in the case of this particular legacy VPN, it did only have single-factor authentication."
> Colonial Pipeline chief executive, answering on multi-factor authentication

> "Senator, that is correct."
> Colonial Pipeline chief executive, answering whether the attack was detected only in the IT network

Source: Threats to Critical Infrastructure: Examining the Colonial Pipeline Cyberattack, US Senate Committee on Homeland Security and Governmental Affairs, S. Hrg. 117-429, 8 June 2021, checked 21 October 2026

INTERPRETATION **What it shows:** Lifecycle and identity: a profile that was not meant to be in use still worked, and it needed only one factor.

INTERPRETATION **What it does not show:** It does not show a compromise of the operational network. The testimony confirms the attack was detected in the IT network; the chief executive also said that, at the time of the hearing, the investigation had not confirmed any evidence of the attackers in the OT system. It says nothing about the industrial remote access design.

Ukrainian power distribution companies, 2015

DATA **WHAT THE RECORD SAYS**

> "During the cyber-attacks, malicious remote operation of the breakers was conducted by multiple external humans using either existing remote administration tools at the operating system level or remote industrial control system (ICS) client software via virtual private network (VPN) connections."

> "The companies believe that the actors acquired legitimate credentials prior to the cyber-attack to facilitate remote access."

> "Remote access should be operator controlled, time limited, and procedurally similar to "lock out, tag out.""

Source: Cyber-Attack Against Ukrainian Critical Infrastructure, US Cybersecurity and Infrastructure Security Agency (CISA), IR-ALERT-H-16-056-01, checked 21 October 2026

INTERPRETATION **What it shows:** Identity and availability: valid credentials over existing, standing remote paths were enough to operate equipment. The agency's own recommendation is a governance one: operator-controlled, time-limited access.

INTERPRETATION **What it does not show:** It does not describe a manufacturer in Belgium or the Netherlands, and the alert does not say how the credentials were obtained beyond that they were acquired before the attack.

Left out: Oldsmar, Florida, water treatment plant (2021). The public record is contested: the former city manager later attributed the event to employee error, and the FBI was reported as unable to confirm an intrusion. A contested case cannot carry a finding.

PART 7

A 90-day plan

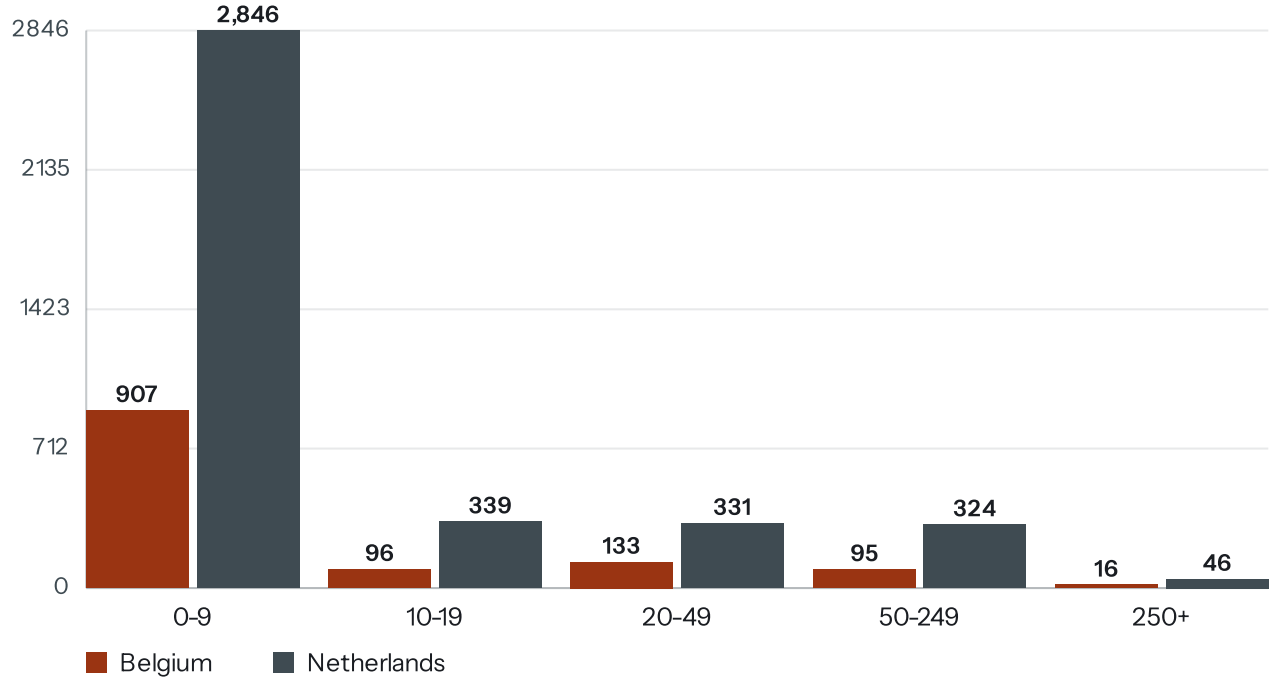
INTERPRETATION Nine steps in three blocks of 30 days. Each has an owner, a deliverable, and a way to verify it was done. The verification column is what turns a step into evidence.

Step	Owner	Deliverable	Verification
DAYS 1 TO 30			
Inventory every remote path: supplier, site, method, account type.	OT security lead	Remote access register	Every row traced to a firewall rule, gateway configuration or account; unknowns listed.
Name an owner for each path, on the plant side and the supplier side.	Plant manager with the builder's service director	Owner columns in the register	No row without two named owners.
Confirm which rules apply in each country of operation, from the official sources.	Compliance or legal	One-page scope note	Each statement cites an official source and a check date.
DAYS 31 TO 60			
Replace shared accounts with named ones, or record why not.	OT security lead with each supplier	Account change log	No shared account without a dated exception.
Turn standing access into on-request, time-limited access where operations allow.	Plant manager	Access procedure: approval, window, end	A sample of sessions shows an approval and a closing time.
Define what evidence is kept for each session, and for how long.	OT security lead	Logging and retention standard	One real session reconstructed from the logs alone.
DAYS 61 TO 90			
Run a revocation test: remove one leaver's access end to end.	Supplier's service director	Revocation record	Access confirmed gone on every path within the target time.
Score the current setup against the matrix in Appendix A and mark unacceptable answers.	OT security lead	Completed matrix	Each unacceptable answer has an owner and a date.
Put the measures to management for approval (NIS2 Article 20, where in scope).	Management body	Signed approval	Minutes or sign-off on file.

PART 8

Regional context

DATA Machinery and equipment manufacturers (NACE C28), 2024: 1,247 enterprises in Belgium, 8.9% with 50 or more persons employed; 3,886 in the Netherlands, 9.5% with 50 or more.



Enterprises in NACE C28 (machinery and equipment n.e.c.) by persons-employed size class, 2024. Share with 50 or more persons employed: Belgium 8.9%, Netherlands 9.5%. Source: Eurostat, dataset sbs_sc_ovw, extracted 21 October 2026.

NIS2's size test is headcount, or annual turnover, or annual balance sheet total, and it counts linked and partner enterprises together. The counts here use headcount (persons employed) as a public, comparable proxy. They size the regional picture; they do not determine whether any specific company is in scope.

INTERPRETATION Most machinery manufacturers in both countries are small by headcount. For them, the rules in Part 5 arrive mainly through the product rules and through in-scope customers' supplier questions, which is why the matrix in Appendix A is written to be answerable by a small builder.

Limitation. Statbel's open-data portal and API were reachable on the extraction date, but no directly comparable published size-class breakdown for NACE 28 could be resolved. Belgium's figures in this report rest on Eurostat alone. The Netherlands figure is cross-checked against CBS table 81589NED (SBI 28, Q4 2026 (provisional, per CBS), extracted 21 October 2026): 370 enterprises with 50 or more employed, a quarterly register count rather than the same survey, so totals differ.

APPENDIX A

The 25-point matrix, prioritised

INTERPRETATION The 25 rows of this site's vendor comparison checklist, regrouped under the five dimensions in Part 4. Use it on your own setup or in a supplier questionnaire. It names no product and scores no one.

Unacceptable answers

Multi-factor authentication is optional or absent. (Identity)
DATA Sources: Directive (EU) 2022/2555, Art. 21(2)(j); Regulation (EU) 2024/2847, Annex I, Part I, point (2)(d); Colonial Pipeline hearing record, S. Hrg. 117-429.

Accounts are shared between people. (Identity)
DATA Sources: Directive (EU) 2022/2555, Art. 21(2)(i); Regulation (EU) 2024/2847, Annex I, Part I, point (2)(d).

Access cannot be scoped below the network level. (Scope)
DATA Sources: Regulation (EU) 2024/2847, Annex I, Part I, point (2)(j).

Revocation needs the supplier's help, or takes longer than your own target. (Lifecycle)
DATA Sources: Colonial Pipeline hearing record, S. Hrg. 117-429.

The customer cannot see who currently has access. (Lifecycle, evidence)
DATA Sources: Directive (EU) 2022/2555, Art. 21(3).

Sessions are not logged, or the logs cannot be exported. (Evidence)
DATA Sources: Regulation (EU) 2024/2847, Annex I, Part I, point (2)(l); Regulation (EU) 2023/1230, Annex III, section 1.1.9.

No answer on the support period or update path of an installed component. (Lifecycle)
DATA Sources: Regulation (EU) 2024/2847, Art. 13(8).

IDENTITY

Whether multi-factor authentication is required	Is MFA mandatory for every connection, or optional and up to us?
Whether accounts are named to a person or shared	Can two engineers share one login, or is every account tied to a named person?
Whether it connects to an existing identity provider	Can this use an existing single sign-on, or does it need its own separate accounts?

SCOPE

How access can be scoped	Can access be scoped to one machine, or does it always reach more of the network?
How access across different customers is kept separate	How is one customer's access kept completely separate from another's?
What has to be installed on the machine itself	What software or hardware has to be added to the machine, and who maintains it?

LIFECYCLE

How access is granted and revoked	How is access granted for a new engineer, and how quickly can it be revoked?
Whether the customer can pause or revoke access without help	Can the customer switch off access themselves, without contacting us first?
Whether the customer can see who currently has access	Can the customer see, in real time, exactly who currently has access?

EVIDENCE

What a session log actually captures	What does the session log capture: keystrokes, a screen recording, or just connection times?
How long logs are kept, and who can export them	How long are logs retained, and can we export our own copy?
Whether session data can feed existing monitoring tools	Can session and log data be exported into the monitoring tools already in use?
Whether logs and configuration can be exported if switching providers	If this is stopped, can the logs and configuration be exported, or are they locked in?

AVAILABILITY

Who can start and stop a session	Can the customer end an active session themselves, at any time?
Whether sessions time out automatically	Does an idle session close itself, and after how long?
How it behaves on a poor or intermittent connection	What happens to an active session if the connection drops, and does it work at all on a low-bandwidth link?

FIT, NOT RISK: IMPORTANT FOR CHOOSING, LOWER PRIORITY FOR GOVERNANCE

Whether it runs on-premises, in the cloud, or both	Can this run entirely within our own network, or does it require a cloud component?
Which industrial protocols and device types are supported	Which protocols and controller types does this actually support today, not on a future roadmap?
Whether older or legacy equipment is supported	Does this work with the equipment already installed, or only with newer models?
Whether one dashboard can manage access across all customers	Can access across every customer site be seen and managed from one place?
What the customer has to do to get this running	What does the customer actually have to do to get this running at a new site?
How long onboarding typically takes	Roughly how long does setup take, from agreement to a first working connection?
What support is available, and where data is processed	What hours is support available, in what time zones, and in which countries is data stored and processed?
Whether pricing is per user, per site, or per connection	Is pricing based on users, sites, machines, or something else, and is that stated plainly?
Whether there are costs beyond the headline price	Are there separate costs for support, extra users, or extra sites beyond the quoted price?

The editable spreadsheet version, with columns for your requirement and suppliers' answers: vendor comparison checklist.

APPENDIX B

Methodology and sources

- Every regulatory quote, date and country fact comes from the compliance ledger kept for this site. Each entry holds the verbatim text, the official URL, the Official Journal reference for EU acts, and the date it was checked.
- EU legal texts were read from the EU Publications Office repository, which serves the Official Journal text, because the EUR-Lex site blocks automated reads. Citations link to the EUR-Lex page for each act so readers can open it in a browser.
- Incidents are cited only from primary records: an official hearing record and a government agency alert, each quoted verbatim with its identifier. Contested cases are excluded.
- Every enterprise figure comes from Eurostat's dissemination API. The Netherlands figure is cross-checked against a CBS business-register table. Belgian figures rest on Eurostat alone; no Statbel cross-check was made for this edition.
- The access-sprawl model in Part 2 is arithmetic on your inputs. The worked example uses illustrative inputs, not observed ones. No figure in this report is projected or estimated.
- No benchmark of respondents is included in this edition.
- No vendor or competitor is named. Architectures are described as generic types, with the assumption stated for each, and are not scored or ranked.

Legal sources (35 ledger entries, grouped by official URL)

Directive (EU) 2022/2555, Art. 21(2)(i) (checked 21 October 2026); Directive (EU) 2022/2555, Art. 21(2)(j) (checked 21 October 2026); Directive (EU) 2022/2555, Art. 21(2)(d) (checked 19 October 2026); Directive (EU) 2022/2555, Art. 20(1) (checked 21 October 2026); Directive (EU) 2022/2555, Art. 21(3) (checked 21 October 2026); Directive (EU) 2022/2555, Annex II, point 5(d) (checked 19 October 2026, wording cross-checked against published copies). OJ L 333, 27.12.2022, p. 80. https://eur-lex.europa.eu/eli/dir/2022/2555/oj/eng

Regulation (EU) 2024/2847, Annex I, Part I, point (2)(d) (checked 21 October 2026); Regulation (EU) 2024/2847, Annex I, Part I, point (2)(l) (checked 21 October 2026); Regulation (EU) 2024/2847, Annex I, Part I, point (2)(j) (checked 21 October 2026); Regulation (EU) 2024/2847, Art. 13(8) (checked 21 October 2026); Regulation (EU) 2024/2847, Art. 13(1) (checked 21 October 2026); Regulation (EU) 2024/2847, Art. 14(1) (checked 21 October 2026); Regulation (EU) 2024/2847, Art. 71(2) (checked 19 October 2026); Regulation (EU) 2024/2847, Art. 71(2) (checked 19 October 2026); Regulation (EU) 2024/2847, Annex III, Class I, points 1 and 5 (checked 21 October 2026). OJ L, 2024/2847, 20.11.2024. https://eur-lex.europa.eu/eli/reg/2024/2847/oj/eng

Regulation (EU) 2023/1230, Annex III, section 1.1.9 (checked 21 October 2026); Regulation (EU) 2023/1230, Annex III, section 1.2.1 (checked 21 October 2026); Regulation (EU) 2023/1230, Art. 10(1) (checked 21 October 2026); Regulation (EU) 2023/1230, Art. 18 and Art. 3, point (16) (checked 21 October 2026); Regulation (EU) 2023/1230, Art. 54 (checked 19 October 2026). OJ L 165, 29.6.2023, p. 1. https://eur-lex.europa.eu/eli/reg/2023/1230/oj/eng

Directive (EU) 2022/2555, Art. 2(1) (checked 19 October 2026); Directive (EU) 2022/2555, Art. 3(2) (checked 19 October 2026). OJ L 333, 27.12.2022, p. 80. https://eur-lex.europa.eu/eli/dir/2022/2555/2022-12-27

Law of 26 April 2024 (Moniteur belge), Art. 98 (checked 19 October 2026); Law of 26 April 2024 (Moniteur belge), Art. 13 §1 (checked 20 October 2026); Law of 26 April 2024 (Moniteur belge), Art. 35 §1 (checked 20 October 2026). https://www.ejustice.just.fgov.be/eli/loi/2024/04/26/2024202344/justel

Staatsblad 2026, 187 and 189 (Art. 35) (checked 19 October 2026). https://zoek.officielebekendmakingen.nl/stb-2026-189.html

Regulation (EU) 2024/2847, Art. 2(1) (checked 19 October 2026). OJ L, 2024/2847, 20.11.2024. https://eur-lex.europa.eu/eli/reg/2024/2847/2024-11-20/eng

Arrêté royal du 9 juin 2024 (Moniteur belge), Art. 3 §1 (checked 20 October 2026). https://www.ejustice.just.fgov.be/cgi/article.pl?language=fr&lg_txt=f&numac_search=2024005260&sum_date=2024-06-24

NCSC-NL, Cyberbeveiligingswet (NIS2) referral-tree overview (checked 20 October 2026). https://www.ncsc.nl/cyberbeveiligingswet-nis2/toezicht-op-de-cyberbeveiligingswet-nis2-hoe-zit-dat

RDI, "Registratieplicht Cyberbeveiligingswet" (checked 20 October 2026). https://www.rdi.nl/onderwerpen/digitale-weerbaarheid/cyberbeveiligingswet/registratieplicht

NCSC-NL, "Meld incidenten onder de Cyberbeveiligingswet (meldplicht)" (checked 20 October 2026). https://www.ncsc.nl/cyberbeveiligingswet-nis2/meldplicht

Legilux gazette record, Loi du 5 mai 2026 (Mémorial A225) (checked 19 October 2026). https://legilux.public.lu/eli/etat/leg/loi/2026/05/05/a225/jo

ILR, "Cybersecurity – NISS" (checked 20 October 2026). https://www.ilr.lu/en/sectors/niss/

ILR, "Self-registration" (checked 20 October 2026). https://www.ilr.lu/en/sectors/niss/self-registration/

ILR, "Incident notification" (checked 20 October 2026). https://www.ilr.lu/en/sectors/niss/incident-notification/

Incident records

Source: Threats to Critical Infrastructure: Examining the Colonial Pipeline Cyberattack, US Senate Committee on Homeland Security and Governmental Affairs, S. Hrg. 117-429, 8 June 2021, checked 21 October 2026. https://www.govinfo.gov/content/pkg/CHRG-117shrg46569/html/CHRG-117shrg46569.htm

Source: Cyber-Attack Against Ukrainian Critical Infrastructure, US Cybersecurity and Infrastructure Security Agency (CISA), IR-ALERT-H-16-056-01, checked 21 October 2026. https://www.cisa.gov/news-events/ics-alerts/ir-alert-h-16-056-01

Data

Source: Eurostat, dataset sbs_sc_ovw, 2024, extracted 21 October 2026 (Enterprise statistics by size class and NACE Rev. 2 activity (from 2021 onwards)). https://ec.europa.eu/eurostat/api/dissemination/statistics/1.0/data/sbs_sc_ovw?format=JSON&lang=EN&geo=BE&geo=NL&nace_r2=C26&nace_r2=C27&nace_r2=C28&nace_r2=C29&nace_r2=C30&nace_r2=C33&indic_sbs=ENT_NR&indic_sbs=EMP_NR&size_emp=TOTAL&size_emp=0-9&size_emp=10-19&size_emp=20-49&size_emp=50-249&size_emp=GE250&sinceTimePeriod=2021

CBS (Statistics Netherlands), table 81589NED, extracted 21 October 2026. https://datasets.cbs.nl/odata/v1/CBS/81589NED/Observations?$filter=BedrijfstakkenBranchesSBI2008 eq '336500' and Perioden eq '2026KW04' and (Measure eq 'M000201' or Measure eq 'WP19096' or Measure eq 'WP19098')

Edition: data and sources checked as of 21 October 2026. Regulatory dates and country facts can change after this date. Check the cited official sources before relying on any of them.